

Glossário

Termos que aparecem nas quatro aulas, em ordem alfabética.

Accessory — Container que o Kamal gerencia mas não faz deploy junto com a aplicação. O Postgres é um. `kamal deploy` não sobe accessory; use `kamal accessory boot|reboot`.

ActiveRecord — O ORM do Rails. Cada classe é uma tabela, cada objeto é uma linha. Equivalente ao Django ORM.

API — *Application Programming Interface*. A porta de entrada do sistema para outros programas. Aqui, uma API REST que responde JSON.

Associação — Ligação entre dois models. `has_many` no lado "um", `belongs_to` no lado "muitos" — que é quem carrega a chave estrangeira.

Base64 — Forma de escrever bytes usando só letras e números, para caber em texto. **Não é criptografia**: não tem chave e qualquer um desfaz. O JWT é Base64.

Bcrypt — Função de hash feita para senha. Lenta de propósito, com fator de custo ajustável e salt aleatório por senha. Ver `02-activerecord.md`.

Bearer — O esquema do cabeçalho `Authorization: Bearer <token>`. "Portador": quem apresenta o token é tratado como o dono dele.

`before_action` — Filtro que roda antes da action do controller. Se ele renderizar algo, a action não é chamada.

Brakeman — Análise estática de segurança para Rails. Procura SQL injection, mass assignment, redirect aberto e afins.

Bundler — O gerenciador de dependências do Ruby. Lê o `Gemfile`, resolve versões e escreve o `Gemfile.lock`.

Autoassinado — Certificado que você mesmo assinou. Criptografa igual a qualquer outro; o que falta é alguém em quem o cliente já confie tendo assinado. É por isso que o navegador reclama.

CA (Autoridade Certificadora) — Quem assina certificados. O navegador nasce com uma lista de CAs em que confia; confiar na CA é confiar em quem ela assinou. Para uma CA pública assinar, você tem que provar que o domínio é seu.

cloud-init — Padrão que quase todo provedor de nuvem usa para configurar uma VM no primeiro boot: usuários, chaves SSH, pacotes. É como a sua chave pública entra na máquina antes de ela existir.

Certificado — Documento que afirma "esta chave pública pertence a este domínio", assinado por uma CA.

Chave estrangeira — Coluna que aponta para o `id` de outra tabela (`login_events.user_id`). Com `foreign_key: true`, o banco recusa linha órfã.

CI/CD — *Continuous Integration / Continuous Deployment*. CI roda testes e verificações a cada push; CD publica automaticamente o que passou.

Concern — Módulo Ruby que uma classe inclui para ganhar um conjunto de métodos. É o mixin do Rails. Vive em `app/models/concerns/` ou `app/controllers/concerns/`.

Container — Uma instância rodando de uma imagem Docker. Descartável.

Cookie — Par nome=valor que o servidor manda no `Set-Cookie` e o navegador reenvia sozinho em toda requisição àquele site. É a memória que o HTTP não tem, colada por fora.

CORS — *Cross-Origin Resource Sharing*. A regra do navegador que impede uma página de um domínio chamar uma API de outro sem permissão explícita. Não se aplica a app nativo.

Credentials — Arquivo YAML criptografado do Rails (`config/credentials.yml.enc`), decriptado pela `master.key`.

Criptografia assimétrica — Duas chaves que se completam: a pública se espalha, a privada nunca sai da máquina. Base do SSH e do TLS.

CSRF — *Cross-Site Request Forgery*. Site malicioso dispara requisição para a sua API, e o navegador anexa o cookie da vítima. Mitigado com `same_site`.

CVE — *Common Vulnerabilities and Exposures*. O identificador público de uma vulnerabilidade conhecida. `bundler-audit` procura CVE nas suas gems.

Denylist — Lista de tokens revogados. No nosso logout, indexada pelo `jti` do JWT.

Digest — O resultado de passar um valor por uma função de hash. `password_digest` guarda o digest, nunca a senha.

DNS — A agenda telefônica da internet: traduz um nome (`api.exemplo.com`) no IP da máquina. A resposta fica em cache pelo TTL.

Docker — Empacota aplicação e dependências numa imagem que roda igual em qualquer lugar.

Dockerfile — A receita da imagem. O nosso é multi-stage: um estágio compila, o final só copia o resultado.

Enumeração de usuários — Ataque em que respostas diferentes (mensagem, status ou tempo) revelam quem tem conta no sistema. Combatido com respostas idênticas e tempo constante.

Fixture — Dados de teste em YAML, carregados antes de cada teste e limpos depois.

Gem — Biblioteca Ruby. O equivalente do pacote do pip.

ghcr.io — GitHub Container Registry. Onde a imagem Docker fica hospedada.

`/etc/hosts` — Arquivo que mapeia nome para IP na sua máquina. O sistema consulta ele **antes** do DNS. É como `seunome.test` acha a VM sem existir em DNS nenhum.

Handshake (TLS) — A negociação inicial: o servidor apresenta o certificado, o cliente valida a cadeia, e os dois combinam uma chave temporária.

Health check — Rota que responde 200 se a aplicação está de pé. A nossa é `/up`. O Kamal só troca o tráfego para o container novo depois que ela passa.

Imagem — A receita congelada: sistema, runtime, dependências e código. Imutável.

IP — O endereço da máquina na rede (`57.156.65.151`). `127.0.0.1` é sempre "esta máquina aqui".

jti — *JWT ID*. Identificador único de um token, usado para revogá-lo individualmente.

JWT — *JSON Web Token*. Cabeçalho, payload e assinatura, em Base64, separados por ponto. O payload é **público**; a assinatura só garante que ninguém o alterou.

Kamal — Ferramenta de deploy com Docker via SSH, feita pela equipe do Rails. Zero-downtime, sem agente na máquina.

Mass assignment — Vulnerabilidade em que o cliente manda um campo que não devia poder mandar (ex.: `role: admin`). Evitada com strong parameters.

Middleware — Camadas que a requisição atravessa antes de chegar ao controller. CORS, cookies e rate limit moram aí. `bin/rails middleware` lista a pilha.

Migration — Mudança no banco, versionada em código, que roda uma vez em cada máquina.

Minitest — O framework de teste que vem com o Rails.

Multipass — Ferramenta da Canonical que cria VMs Ubuntu com um comando. É o que sobe o servidor da Aula 4.

mise — Gerenciador de versões de runtime. O `pyenv` do mundo Ruby.

MVC — *Model-View-Controller*. Model = dados e regras; View = a saída (aqui, JSON); Controller = recebe a requisição e decide.

N+1 — Carregar uma lista e depois consultar o banco item a item. 100 registros viram 101 consultas. Resolve-se com `includes`.

NSG — *Network Security Group*. O firewall da Azure, fora da máquina, com regras de entrada e saída por porta e origem. É o equivalente na nuvem do `ufw`, e vem antes dele: o pacote nem chega.

OIDC — *OpenID Connect*. Permite o GitHub Actions autenticar na nuvem com um token de curta duração, sem guardar segredo de longa duração. Aparece no apêndice de nuvem.

OOM killer — O mecanismo do kernel Linux que mata processos quando a RAM acaba. É por isso que a VM tem swap.

Origin CA — Certificado emitido pelo Cloudflare para o trecho Cloudflare → seu servidor. Navegador não confia nele diretamente, e não precisa: o usuário vê o certificado público do Cloudflare.

PAT — *Personal Access Token*. Token do GitHub que substitui a senha em ferramentas de linha de comando. O do curso tem só `write:packages` e `read:packages`, para o `ghcr.io`.

ORM — *Object-Relational Mapping*. Traduz objetos em linhas de tabela.

OTP — *One-Time Password*. O código de 6 dígitos, válido por 15 minutos e uma vez só.

Payload — O miolo do JWT, onde ficam `sub`, `exp`, `jti`. Público.

Porta — Número de 1 a 65535 que identifica um programa dentro da máquina. 22 SSH, 80 HTTP, 443 HTTPS, 5432 Postgres, 3000 Rails em dev.

Postgres — O banco relacional que usamos em desenvolvimento e em produção.

Proxied (Cloudflare) — Nuvem laranja no DNS: o tráfego passa pelo Cloudflare antes de chegar à sua máquina, e o IP real não aparece no DNS.

Proxy reverso — Fica na frente do servidor: recebe na 443, termina o TLS e repassa para a aplicação em HTTP interno. O `kamal-proxy` é um.

Puma — O servidor web do Rails.

rack-attack — Middleware que bloqueia abuso por IP. Está no `seem-backend`, não no app do curso.

Registry — Repositório de imagens Docker. O "GitHub das imagens".

REST — Estilo de organizar a API: cada coisa é um recurso com um endereço, e o verbo HTTP diz o que fazer com ele.

Rollback — O banco desfazendo uma transação que falhou no meio. Também: `kamal rollback`, que volta para a versão anterior da imagem.

root — O usuário do Linux que pode tudo, sem confirmação. Você trabalha como usuário comum e chama `sudo` quando precisa.

RuboCop — O linter de Ruby. O `black` / `ruff` do mundo Python.

Salt — Valor aleatório misturado à senha antes do hash, para que senhas iguais gerem digests diferentes. O bcrypt gera um por senha, automaticamente.

Scope — Consulta com nome, definida no model e encadeável:

```
user.login_events.recentes.limit(5)
```

Serializer — Decide o que de um objeto vai para o JSON — e, principalmente, o que não vai.

Service object — Classe que representa um caso de uso (`Users::Register`). Tira a regra de negócio do controller.

Solid Cache / Solid Queue — Cache e fila do Rails 8, guardados no próprio Postgres. A denylist do logout usa o cache.

Strong parameters — Filtro que declara quais campos a requisição pode mandar. No Rails 8, `params.expect`.

Struct — Classe de uma linha para agrupar valores sem comportamento. O `namedtuple` / `dataclass` do Ruby. Todo service do projeto devolve um.

sub — *Subject*. O claim do JWT que diz de quem é o token — no nosso caso, o `user.id`.

Swap — Área em disco usada como extensão da RAM. Lenta, mas evita que o OOM killer mate a aplicação.

`.test` — Domínio de topo reservado para testes por RFC. Ninguém consegue registrar, então nunca colide com um site de verdade.

TLS — O túnel criptografado que embrulha o HTTP e o transforma em HTTPS. Mesmo protocolo, só que fechado.

Token version — Contador no `User` que vai dentro do JWT. Incrementar invalida todos os tokens daquele usuário de uma vez.

Transação — Bloco em que ou tudo acontece, ou nada acontece. `User.transaction do ... end`.

TTL — *Time To Live*. Por quanto tempo algo vale. Nosso código OTP tem TTL de 15 minutos; as entradas da denylist têm o TTL do que restava do token.

Variável de ambiente — Par nome=valor que o sistema entrega ao processo. Lida com `ENV["NOME"]`. É como configuração e segredo entram sem passar pelo código.

Volume (Docker) — Área de disco que sobrevive ao container. É o que faz o banco não sumir a cada deploy. **Não é backup.**

ufw — *Uncomplicated Firewall*. A casca amigável do firewall do Ubuntu. `ufw allow 22/tcp`.

VM — *Virtual Machine*. Um computador inteiro simulado em software: kernel, disco, rede, usuários. É o que o Multipass cria no seu notebook, e é o que uma VPS é do outro lado.

VPS — *Virtual Private Server*. Uma VM alugada, num datacenter, com IP público. Mesma coisa que a VM da Aula 4 — só que exposta ao mundo e cobrada por hora ligada.

WSL2 — *Windows Subsystem for Linux*. Um Linux de verdade dentro do Windows. Obrigatório para quem desenvolve Rails no Windows.

XSS — *Cross-Site Scripting*. O atacante roda JavaScript dentro da sua página, geralmente porque você exibiu texto de usuário sem escapar. É contra isso que `httponly` protege o token.

Zeitwerk — O autoloader do Rails. Descobre o arquivo pelo nome da classe:

`Api::V1::StatusController` → `app/controllers/api/v1/status_controller.rb`. É o que dispensa o `require`.

Índice — Estrutura no banco que acelera busca. Com `unique: true`, vira restrição: o banco recusa duplicata mesmo com duas requisições simultâneas.